

SQL 判题考试系统——汇报讲稿

刘翔宇、孙晓博、黄竺

2026 年 6 月 28 日

PPT 部分 (1 分钟)

第 1 页 (约 25 秒)

期中之后我们主要做了三块工作。

安全方面，最大的改动是引入了 JSqlParser 做 AST 级别的语法校验。原来只靠关键字黑名单过滤危险 SQL，但测试发现 UNION 可以绕过单 SELECT 限制，学生能通过 UNION 执行子查询来读取任意数据。我们改为在语法树层面做校验，非 PlainSelect 结构一律拦截。同时修复了考试越权访问的问题——之前学生只要知道 examId 就能查看任何考试的详情，现在后端做了考试和学生关联关系的校验。异常信息泄漏也做了脱敏处理，生产环境不再暴露 SQL 语句和表名。

功能方面，考试向导从三步扩展到了四步，新增了分配考生环节，之前考试创建完没法指定哪些学生参加，现在可以在向导里直接勾选。教师创建班级、管理员用户管理、密码修改这三个模块是期中之后从零开发的。管理员的用户管理支持创建用户、调整角色、启用禁用账号，前后端都做了权限校验。

体验方面，仪表盘从写死的数据改成了数据库实时查询——已解决题目数、正确率、连续练习天数这些指标现在会随学生提交动态变化。搜索从只匹配标题扩展到了同时匹配描述，搜 Employee 能命中五道相关题目。HTTP 异常也统一做了规范化，非法 JSON 请求体现在返回 400 而不是 500。

第 2 页 (约 20 秒)

判题引擎是整个系统安全风险最高的模块，期中之后我们把它完善成了三层防护。

第一层是关键字黑名单，直接拦截 DROP、INSERT、DELETE、ALTER、TRUNCATE、GRANT、REVOKE 这些危险操作。

第二层是分号计数，不允许多语句提交。我们通过比较首个和末个分号的位置来判断——如果首尾分号位置不同，说明存在多个分号，拒绝执行。

第三层也是最关键的一层，用 JSqlParser 解析 SQL 语句生成 AST 语法树。如果解析出来的根节点不是 Select 下的 PlainSelect——比如是 UNION 查询或者包裹了子查询 DML——直接拒绝，这才从根上堵住了绕过的可能。

执行环境上，每次判题创建独立的临时 MySQL schema，命名格式是 judge_ 题目 ID_ 时间戳 _UUID，确保多次执行不冲突。执行完马上在 finally 块里删掉，即使判题过程抛异常也不会残留。设了 5 秒的语句超时，防止慢查询拖垮服务器。判题用的 MySQL 账号权限限定在临时 schema 范围内，没有业务库的任何访问权限。

第 3 页 (约 15 秒)

测试方面，我们做了两轮深度测试。

第一轮覆盖了 28 个 API 端点和 14 个前端页面，找了 20 项问题包含安全漏洞、功能空桩、状态码不规范等。第二轮在全部修复后又反复验证发现 15 项新问题，包括 UNION 绕过、锁定时考试可被再次发布、管理员看不到考试列表这些。35 项全部修复并通过复测。40 多个边界测试用例和 SQL 注入攻击用例全部通过。三种角色的鉴权矩阵——核对，每种角色对每个接口的访问权限都验证正确了。整体完成度 98%。

下面进入系统演示。

演示部分 (4 分钟)

学生端——仪表盘 + 判题

好，我们开始系统演示。先以学生身份登录。系统内置了三个默认账号，admin、teacher1、student1，密码统一是 password。Flyway 迁移脚本在启动时自动创建，保证每个人部署出来环境一致。

登录进来是学生工作台。期中之后的改动一眼能看出来——最上面的已解决题目数、正确率、连续练习天数，以前是写死的假数据，现在全部从数据库实时计算。已解决题目数统计的是日常练习中不同题目的 AC 次数，正确率是总 AC 提交除以总提交次数，连续天数按提交记录的日期去重后倒推。下面列出即将到来的考试和推荐题目，推荐逻辑暂时按难度和标签匹配，后续可以扩展更智能的推荐算法。

现在点进一道题。我选第 184 题，部门工资最高的员工，难度是中等。左侧是题目描述和表结构，表结构是从 sourceSchemaSql 字段渲染出来的。右侧是 SQL 代码输入区，支持基本的文本编辑。切换题目前草稿会保留在当前页面会话中。

我现在写一个查询，查每个部门工资最高的员工，用子查询找出每个部门的最大工资然后匹配。写完点运行自测，这个接口是 run，只跑公开测试用例，不写记录不计成绩。系统返回 Accepted，绿色标记，右侧展示实际输出的列名和数据行。如果答案错了会返回 Wrong Answer 并显示期望结果和实际结果的对比。

确认无误之后点提交代码，调用 submissions 接口写入正式记录。如果是在考试中提交的，会自动关联 examId 并触发成绩重算。侧边栏的提交历史可以看到每次提交的状态、得分、耗时和错误信息。

学生端——考试作答

接下来看考试作答流程。回到学生工作台，在即将考试的区域可以看到已经被分配的考试。点击进入。

期中之前考试页面只能显示一道题，学生没法切换到其他题。期中之后做了大幅改进——顶部新增了题号导航栏，所有题目一目了然，点哪个切哪个。每道题维护独立的 SQL 草稿和判题结果，切走不会丢上一题的代码和判题状态。考试计时在页面顶部实时显示。如果老师设置了时长限制，到了时间会自动锁屏不能继续提交。

异常状态处理也是期中之后补上的。如果老师在考试发布后又删了一道题，学生进来不会白屏，会显示题目不可用。网络请求失败也有重新加载按钮。考试结束后系统自动汇总成绩——每道题取该学生所有提交中的最高分，按照老师在考试里设的权重汇总。学生端的成绩只能看，不能改。

教师端——仪表盘 + 题库 + 考试向导

现在切换到教师端，用 teacher1 登录。

教师仪表盘的数据期中之后全部动态化。活跃班级数从 classes 表按 teacherId 统计。题库总量按 visible=1 条件计数。待处理提交这个数字很有意思，它查的是状态为 ERROR 或者 FORBIDDEN 的提交，提醒老师去看是不是有学生的 SQL 需要指导。最近考试列表按创建时间倒序，显示状态标签。

进题库管理页面。列表做了服务端分页和搜索。期中之后搜索从只匹配标题扩展到了同时匹配题目描述，中文和英文关键词都支持。教师编辑一道题的时候可以看到参考答案和测试用例的明文，而学生端同一个接口返回的这两个字段是 null。这个权限控制在后端 QuestionService 里根据角色做判断，前端只是不展示，真正的安全靠后端 @JsonInclude 注解隐藏空字段。

点击创建考试，这是期中之后改动最大的模块。原来只有一步配置表单，现在扩展成四步向导。第一步配置考试参数——名称、开始时间、结束时间、考试时长、考试说明。时间校验要求结束时间必须晚于开始时间，时长必须大于零。第二步从题库里搜索和勾选题目，支持按难度和关键词筛选。第三步给每道题设分值，同时可以调整题目在考试中的排列顺序。第四步是期中之后新增的，勾选参加考试的学生。所有校验在每一步都会实时给出提示，比如没选题点不了下一步，分值没填完会有红色提醒。创建完是草稿状态，点发布后学生才能看到。

教师端——成绩统计

成绩统计这个页面期中之前是空白页，期中之后从零开发出来的。教师先在下拉框选一场考试，系统调用 scores 接口返回所有参加考试的学生成绩。表格展示排名、学生姓名、最终得分、考试状态——是已提交还是未开始还是缺考。页面顶部额外计算了班级平均分和最高分，方便教师掌握整体情况。

这里要强调，最终成绩是由后端自动汇总的——把该学生在考试中每道题的最高提交分加起来写入 `exam_students.final_score`。前端只负责展示和触发重新计算，不能直接传一个分数过去。防止学生或者前端代码篡改成绩。

管理员——用户管理

切到管理员端，用 `admin` 登录。

管理员用户管理是期中之后新增的模块，之前完全没有管理员功能。现在管理员可以看到系统所有用户的列表，包括用户名、真实姓名、角色、账号状态。点击新增用户可以填用户名密码并选择角色——学生、教师、管理员、助教。编辑用户支持修改角色和状态，比如把一个学生升级为助教，或者禁用某个账号。修改密码字段如果留空就不改动原密码。

权限方面，管理员接口全部用 `@PreAuthorize` 标注了 `ADMIN` 角色，教师和学生调这些接口直接返回 403。反过来管理员也能访问教师和学生的所有功能——仪表盘、题库、考试、成绩——因为管理员角色在权限注解里和教师并列。

安全演示 + 收尾

最后展示一下判题引擎的安全性，这也是期中之后加固最多的地方。

我回到学生端的编辑器，输入一句 `DROP TABLE Employee`，点击运行。系统没有执行，而是直接返回了 403 和提示信息——“只允许查询类 SQL”。这不是简单的字符串匹配，前面提到的三层防护在这里一起生效：关键字黑名单先命中 `DROP`，即便换个写法绕过了关键字，分号检查和多语句拦截还在，就算前两层都没拦住，`JSqlParser` 解析发现这不是 `PlainSelect`，照样拒绝。

换个更隐蔽的例子——如果我写 `SELECT` 语句套一个 `UNION` 去查其他表的数据，系统也能识别出来。因为 `JSqlParser` 检测到这是 `SetOperationList` 而不是 `PlainSelect`，拒绝执行。

执行环境的隔离是最后一道保险。退一万步说，即使前面的拦截全部失效，判题 SQL 也只有一个临时 `schema` 里跑，这个 `schema` 里只有那道题的测试数据，删了也不影响业务库。执行完 `finally` 块保证清理，不会留下任何痕迹。

以上就是我们系统期中之后的主要改动和完整功能演示。总结一下：安全方面建立三层判题防护，从关键字到 AST 解析到执行隔离；功能方面补全了考试四步向导、班级管理、管理员用户管理三个大模块；体验方面实现了仪表盘动态化、搜索增强、异常规范化。整个系统经过两轮深度测试，28 个 API 端点、14 个前端页面、三种角色的鉴权矩阵全部验证通过，40 多个边界安全用例全部绿灯。核心教学闭环——学生练习、自动判题、在线考试、成绩统计——全部可用。

谢谢，请老师提问。